

VibSecSys OCTAVE and STRIDE Security Analysis Report

1. Scope and Source

This report is based exclusively on the provided **VibSecSys Security Report**.

Scope covers the three identified hosts:

- **192.168.56.20** — high-exposure host with multiple legacy and administrative services
- **192.168.56.30** — limited exposure with SSH and HTTP
- **192.168.56.50** — Windows-related services including MSRPC, NetBIOS, and SMB

No additional systems, services, or assumptions have been introduced beyond the source findings.

2. OCTAVE Analysis

2.1 Key Assets

The source report indicates the following key assets and exposure domains:

- **Remote access and administration services** on 192.168.56.20, including SSH, Telnet, VNC, X11, exec, login, and bindshell
- **File-sharing and network services** including FTP, NFS, SMB/NetBIOS, and rpcbind
- **Database services** including MySQL and PostgreSQL
- **Web/application middleware** including HTTP, AJP13, Java RMI, and IRC
- **Windows file-sharing services** on 192.168.56.50
- **Authenticated access mechanisms and credentials** potentially exposed through cleartext or weakly protected services

The most critical asset from a security perspective is **192.168.56.20**, due to its unusually broad service exposure and presence of services described as legacy, insecure, or suspicious.

2.2 Threat Scenarios

Based on the source findings, the principal threat scenarios are:

- **Credential interception** through cleartext protocols such as Telnet and FTP, and potentially weakly protected VNC/X11 access
- **Unauthorized remote access** via exposed administrative services, including exec/login-style services and bindshell
- **Remote exploitation or misconfiguration abuse** of rpcbind, NFS, Java RMI, and AJP13
- **Database compromise** through direct exposure of MySQL and PostgreSQL
- **Lateral movement and credential attacks** using SMB/NetBIOS exposure on 192.168.56.50
- **Web/application abuse** through exposed HTTP services and AJP13
- **Denial of service or service disruption** against broadly exposed services on the high-risk host

2.3 Potential Impact

The source report supports the following potential impacts:

- **Unauthorized access** to systems and services
- **Credential theft** due to cleartext transmission
- **Data exposure or exfiltration** from databases, file-sharing services, or backend application services
- **Lateral movement** within the network, especially through SMB/NetBIOS
- **Privilege escalation** where insecure administrative or backdoor-like services are reachable
- **Operational disruption** if critical exposed services are abused or taken offline

The impact is highest on **192.168.56.20**, where the number and type of services create a broad attack surface. **192.168.56.30** presents a smaller but still relevant exposure profile. **192.168.56.50** is more limited, but SMB/NetBIOS exposure remains a concern if not restricted.

2.4 Risk Priorities

Priority should be assigned as follows:

1. Contain or isolate 192.168.56.20

- This host is assessed as **high to critical risk** in the source report.
- Particular concern exists around Telnet, FTP, exec/login, bindshell, VNC, X11, NFS, SMB, MySQL, PostgreSQL, and AJP13.

2. Restrict Windows file-sharing exposure on 192.168.56.50

- SMB/NetBIOS should be limited to trusted internal networks.

3. Validate 192.168.56.30

- SSH and HTTP are comparatively minimal, but still require hardening and patch validation.

4. Determine whether the environment is intentionally vulnerable

- The presence of bindshell and exec/login services is highly atypical and may indicate a lab or training environment.
- If not intentional, the environment should be treated as urgently remediated.

2.5 Control Priorities

The source report identifies the following control priorities:

- **Reduce attack surface** by disabling unnecessary services
 - **Replace insecure protocols** such as Telnet and FTP with secure alternatives
 - **Restrict access by network controls** for SSH, databases, SMB, NFS, and AJP13
 - **Harden authentication** using strong credentials, key-based SSH, and removal of unused accounts
 - **Patch and validate service versions** across exposed services
 - **Secure file-sharing and database services** through interface restrictions and least privilege
 - **Implement logging and monitoring** for brute-force activity, suspicious connections, and lateral movement
 - **Confirm production versus lab status** to determine whether immediate containment is required
-

3. OCTAVE Summary Table

Category	Details
Key Assets	192.168.56.20 services: Telnet, FTP, SSH, VNC, X11, NFS, SMB, MySQL, PostgreSQL, HTTP, AJP13, rpcbind, exec, login, bindshell, SMTP, DNS, Java RMI, IRC; 192.168.56.30: SSH, HTTP; 192.168.56.50: MSRPC, NetBIOS, SMB
Threat Scenarios	Credential interception, unauthorized remote access, remote exploitation, database compromise, lateral movement, web/application abuse, service disruption
Potential Impact	Unauthorized access, credential theft, data exposure/exfiltration, privilege escalation, operational disruption
Risk Priorities	Highest risk on 192.168.56.20; moderate exposure on 192.168.56.50; lower but still relevant exposure on 192.168.56.30; confirm lab vs production
Control Priorities	Disable unnecessary services, replace insecure protocols, restrict network access, harden authentication, patch services, secure file-sharing/database services, enable logging and monitoring

4. STRIDE Analysis

4.1 Spoofing

The source report indicates conditions that support spoofing risk, particularly where weak or cleartext authentication is possible. Examples include Telnet, FTP, SMTP, and potentially weakly protected VNC or X11 access. An attacker could impersonate a legitimate user or service endpoint when credentials or session material are exposed or insufficiently protected.

Impact: Unauthorized access to systems and services, credential theft, and misuse of administrative pathways.

Mitigation: Replace insecure protocols with secure alternatives, enforce strong authentication, prefer key-based SSH, restrict access to trusted networks, and harden any remote administration interfaces.

4.2 Tampering

Exposed services such as FTP, NFS, SMB, web/application services, and databases may permit unauthorized modification of files, data, or application traffic if controls are weak. AJP13 and rpcbind/NFS are especially sensitive where misconfiguration may expose backend resources or mounted content.

Impact: Data alteration, file corruption, unauthorized configuration changes, and potential compromise of application integrity.

Mitigation: Restrict service exposure, apply least privilege, limit database and file-sharing access to approved clients, and patch or disable unnecessary services.

4.3 Repudiation

The report notes the need for centralized logging and monitoring across SSH, FTP, SMTP, web, database, SMB, and NFS services. Without sufficient logging, users or attackers may deny having accessed or altered systems,

especially on a host with many exposed services.

Impact: Inability to attribute actions, weakened incident response, and reduced forensic confidence.

Mitigation: Enable centralized logging, retain access records, monitor for unusual sessions and brute-force attempts, and review administrative access regularly.

4.4 Information Disclosure

This is a primary risk in the source report. Telnet and FTP transmit credentials and data in cleartext unless secured; HTTP may expose unencrypted content; SMB, NFS, and database services can leak data if not properly restricted. VNC/X11 also pose disclosure risk if weakly protected or exposed broadly.

Impact: Credential interception, session hijacking, exposure of sensitive files or database contents, and backend application leakage.

Mitigation: Replace cleartext protocols, enforce encrypted access where available, restrict exposure by network controls, and validate authentication and authorization settings.

4.5 Denial of Service

The broad attack surface on 192.168.56.20 and the presence of multiple externally reachable services increase the likelihood of service disruption through abuse, flooding, or resource exhaustion. Exposed administrative and middleware services are especially sensitive to misuse.

Impact: Service downtime, degraded availability, and disruption to dependent systems or administrative workflows.

Mitigation: Limit exposure through host firewalls and ACLs, disable unneeded services, monitor connection patterns, and isolate the host if it is not intentionally vulnerable.

4.6 Elevation of Privilege

The report specifically identifies exec/login services and a bindshell on 192.168.56.20, which are highly unusual in production and strongly suggest elevated-risk access paths. Insecure service exposure may allow attackers to move from limited access to administrative control.

Impact: Full host compromise, expanded access to internal resources, and potential lateral movement to other systems.

Mitigation: Remove or isolate bindshell and exec/login services, harden authentication, apply least privilege, and treat the host as critical if it is a production system.

Mitigation: Remove or isolate bindshell and exec/login services, harden authentication, apply least privilege, and treat the host as critical if it is a production system.

5. STRIDE Threat Model Table

Category	Threat Example	Impact	Mitigation
Spoofing	Impersonation via cleartext or weakly protected access such as Telnet, FTP, SMTP, VNC, or X11	Unauthorized access, credential theft	Replace insecure protocols, enforce strong authentication, restrict access to trusted networks
Tampering	Unauthorized modification through exposed FTP, NFS, SMB, web services, or database access	Data alteration, file corruption, integrity loss	Restrict exposure, apply least privilege, patch services, limit access to approved clients
Repudiation	Lack of adequate logging for SSH, FTP, SMTP, web, database, SMB, and NFS activity	Poor accountability and weak forensics	Centralized logging, session monitoring, retention of access records
Information Disclosure	Cleartext transmission over Telnet or FTP; exposure of HTTP, SMB, NFS, and database services	Credential interception, data leakage, session hijacking	Use secure alternatives, encrypt access, restrict network exposure
Denial of Service	Abuse of the heavily exposed service set on 192.168.56.20	Service disruption and downtime	Reduce attack surface, isolate the host, monitor traffic patterns, disable unneeded services
Elevation of Privilege	Bindshell and exec/login-style services on 192.168.56.20	Host compromise and lateral movement	Remove or isolate suspicious services, harden authentication, enforce least privilege

6. Overall Risk Summary

The source report indicates that **192.168.56.20** is the dominant risk driver and should be treated as **high to critical risk** due to its extensive exposure to legacy, insecure, and potentially suspicious services. The presence of **Telnet, FTP, exec/login, bindshell, VNC, X11, NFS, SMB, MySQL, PostgreSQL, and AJP13** creates a broad opportunity for unauthorized access, credential compromise, data exposure, and privilege escalation.

192.168.56.30 presents a **low to moderate risk** profile because it exposes only SSH and HTTP, though hardening and patch validation remain necessary.

192.168.56.50 is **moderate risk**, with SMB/NetBIOS exposure that should be restricted to trusted networks and properly secured.

Overall, the environment appears either intentionally vulnerable or significantly misconfigured. If this is not a lab environment, the most appropriate response is immediate containment, service reduction, and network restriction, followed by hardening, monitoring, and verification of service necessity.

